



SICUREZZA DELL'INFORMAZIONE M

Diffie-Hellman:

Vulnerabilità MitM e Difesa Challenge-Response

Implementazione pratica e simulazione in Python 3 — analisi del protocollo di scambio chiavi e delle sue proprietà di sicurezza

Descrizione del Progetto

Tre scenari progressivi dimostrano un percorso completo: dal protocollo ideale, all'attacco, alla difesa.



Scenario 1

Scambio Diffie-Hellman

Funzionamento corretto del protocollo DH tra Alice e Bob in condizioni ideali, senza avversari.



Scenario 2

Attacco Man-in-the-Middle

Eve intercetta e sostituisce le chiavi pubbliche, ingannando entrambe le parti senza essere rilevata.



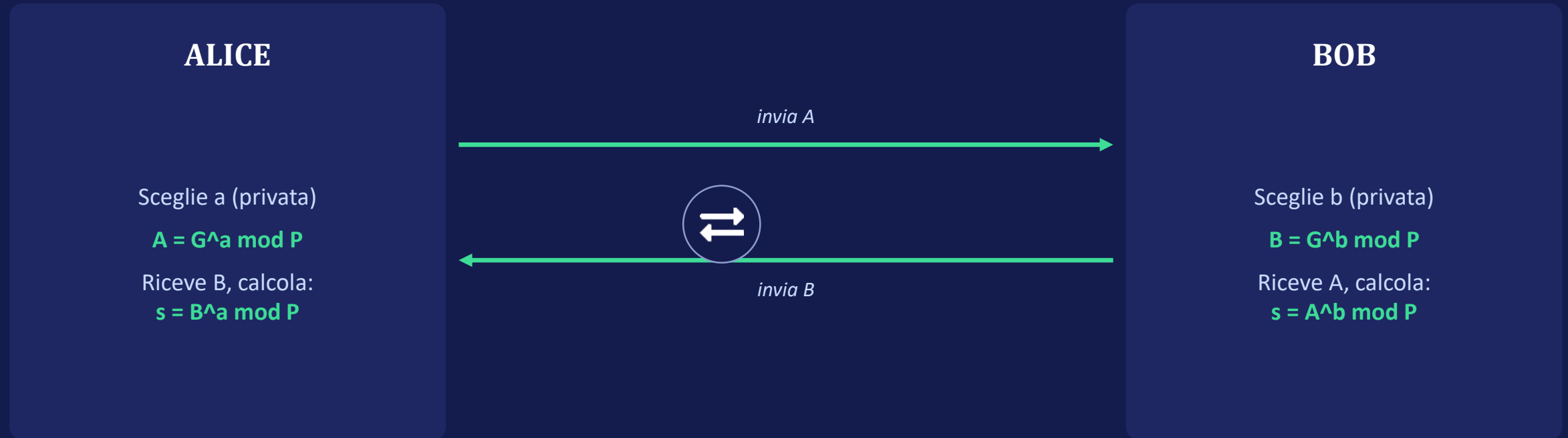
Scenario 3

Difesa Challenge-Response

Autenticazione HMAC-SHA256 con chiave pre-condivisa (PSK) prima dello scambio DH, per bloccare il MitM.

Fondamenti: il Protocollo Diffie-Hellman

Due parti concordano un segreto condiviso su un canale pubblico, senza mai trasmetterlo esplicitamente (RFC 3526, MODP Group 14, P a 2048 bit)



Segreto condiviso: $s = G^{(ab)} \bmod P$ — mai trasmesso sul canale

Sicurezza basata sul Problema del Logaritmo Discreto (DLP): ricavare a da $A = G^a \bmod P$ è computazionalmente intrattabile

Il Problema: Nessuna Autenticazione

DH garantisce riservatezza ma non autenticazione: un attaccante attivo può impersonare entrambe le parti



Eve genera due coppie di chiavi DH: instaura un segreto separato con Alice e uno con Bob, restando invisibile nel mezzo del traffico cifrato

Cosa crede ciascuna parte

Parte	Calcola	Crede di parlare con
Alice	$G^{(e_2 \cdot a)} \bmod P$	Bob
Bob	$G^{(e_1 \cdot b)} \bmod P$	Alice
Eve	entrambi i segreti	— <i>li conosce tutti e due</i>



Perché Eve riesce

DH base non include alcun binding tra chiave pubblica e identità: un valore trasmesso è anonimo, chiunque può spacciarlo per la chiave pubblica di un'altra parte.

Scenario 3 — Difesa Challenge-Response con HMAC

Autenticare l'identità PRIMA che avvenga lo scambio DH, usando una chiave pre-condivisa (PSK) concordata fuori banda



Perché Eve fallisce: può leggere il nonce (in chiaro), ma senza conoscere la PSK non può calcolare una firma HMAC valida — l'output è indistinguibile da un valore casuale.

Proprietà di Sicurezza & Scelte Implementative

DH Base vs DH + Challenge-Response

Proprietà	DH Base	DH + CR
Riservatezza	✓	✓
Autenticazione origine	✗	✓
Resistenza a MitM attivo	✗	✓
Resistenza a timing attack	✗	✓ (compare_digest)

Perché queste scelte



Solo libreria standard

hmac, hashlib, os — nessuna dipendenza esterna: portabilità e trasparenza didattica del codice.



RFC 3526 MODP Group 14

Primo sicuro a 2048 bit e generatore G=2: parametri standard e sicuri, non improvvisati.



PSK fuori banda

La chiave condivisa non transita mai sul canale osservato da Eve: rimuove il punto debole del binding identità-chiave.



hmac.compare_digest

Confronto a tempo costante per evitare timing attack durante la verifica della firma.



Conclusioni

Il progetto mostra, con un percorso a tre tappe, perché l'autenticazione è indispensabile in ogni scambio di chiavi pubblico: la sola riservatezza di Diffie-Hellman non basta contro un avversario attivo.

- ✓ DH garantisce riservatezza ma non identità
- ✓ Un MitM attivo può violare la sessione senza essere notato
- ✓ Una PSK + HMAC-SHA256 chiude la falla prima dello scambio DH

Come eseguire il progetto

```
$ python3 main.py
```

Richiede solo Python 3.6+, nessuna dipendenza esterna. L'output mostra i tre scenari in sequenza, con ogni passo numerato e commentato.